

2.

정보 출처



성공적인 취약점 관리 프로그램을 운영하려면 여러 데이터 소스의 정보가 필요합니다. 이 장에서는 이러한 각 소스를 소개합니다. 다음 장에서는 이러한 모든 소스가 어떻게 통합되어 조직에 유용한 취약점 현황을 제공하는지 살펴보겠습니다.

자산 정보

자산 정보의 중요성에도 불구하고, 규모와 상관없이 많은 조직들이 자사 네트워크에 있는 자산에 대해 완전하거나 심지어 단편적인 정보만을 보유하고 있습니다. 네트워크 관리자들끼리 공유하고 주기적으로 업데이트하는 스프레드시트를 사용하거나, CMDB 또는 엔드포인트 관리 제품을 이용해 Windows 데스크톱 데이터베이스를 구축하는 경우도 있을 것입니다. 하지만 취약점 관리를 위해서는 IP에 연결된 모든 장치와 각 장치에 대한 추가 정보를 포함한 완벽한 인벤토리가 필요합니다. 호스트, 네트워크에 연결되지 않은 장치는 전반적인 위험 평가에 중요하지만 자동화된 취약점 관리 프로그램의 범위에서 제외됩니다.

호스트 목록은 물론이고 그 외 다양한 추가 정보까지 얻는 것은 어렵지 않습니다. Nmap과 같은 네트워크 스캔 도구나 Nessus 또는 Qualys와 같은 취약점 스캐너(취약점 데이터를 수집하려면 어차피 이러한 도구들이 필요합니다)를 사용하여 네트워크를 스캔하고 활성 호스트를 찾을 수 있습니다. 하지만 이러한 스캔은 시스템에 부담을 줄 수 있으며, 애플리케이션이나 운영체제에 충돌을 일으킬 수도 있습니다. 따라서 정보 수집 목적의 스캔을 진행할 때는 신중하게 계획해야 합니다.

네트워크에는 새로운 장치가 끊임없이 추가되며, 대부분의 조직이 변경 관리 정책을 시행하고 있지만, 정책을 준수하지 않은 변경이 발생하지 않는다는 보장은 없습니다. 최신의 신뢰할 수 있는 자산 정보를 확보하려면 전체 네트워크에 걸쳐 정기적으로 검색 스캔을 수행해야 합니다.

이상적으로는 이러한 검사를 정기적으로 실행하는 것이 좋습니다. 하지만 정기적인 검사의 위험성(다음 섹션에서 자세히 설명) 때문에 조직에서는 사람이 직접 모니터링하고 문제가 발생할 경우 검사를 중단할 준비가 되어 있지 않으면 이러한 검사를 실행하지 않는 것이 불안할 수 있습니다. 이러한 경우에는 검색 검사 횟수를 줄이고 수동으로 검사를 실행한 다음 결과 데이터를 데이터 저장소로 가져와야 합니다.

변화 관리

위험 관리 체계를 갖춘 모든 조직은 시스템과 네트워크가 안정적인 상태를 유지하고 변경 사항을 기록하기 위한 변경 관리 시스템을 보유하고 있습니다. 이러한 시스템은 변경 요청, 승인 및 조정을 위한 이메일 체계부터 티켓팅 및 구성 관리를 포함하는 완전한 상용 변경 관리 시스템에 이르기까지 다양합니다.

변경 관리 시스템만으로는 IT 변경에 대한 유일한 통제 수단이 될 수 없으며, 되어서도 안 됩니다. 변경 관리를 우회하는 방법은 항상 존재합니다. 관리자는 패치를 적용하거나 적용하지 않고, 문제를 해결하기 위해 네트워크 경로를 추가 및 변경하고, 새로운 네트워크 장비를 구매 및 연결하고, 비즈니스 요구 사항을 충족하기 위해 새로운 서비스를 활성화하는 등의 작업을 수행하면서도 필요한 변경 관리 기록을 남기지 않는 경우가 있습니다. 따라서 변경 관리 시스템이 IT 인프라의 상태에 대해 제시하는 정보를 신뢰할 수 없습니다.

취약점 정보

네트워크상의 모든 장치에 대한 완전한 정보를 확보한 후에는 취약점 스캐너를 구성하여 각 장치를 심층 검사하고 알려진 호스트 취약점을 찾아낼 수 있습니다. 예를 들어, 스캐너는 다음과 같은 취약점을 찾아낼 수 있습니다.Windows 서버에서 디렉터리 탐색 공격에 취약한 IIS 웹 서버 버전이 실행 중이라는 사실입니다. 이로 인해 정보 유출이 발생할 수 있습니다.

스캔을 구성하고 예약할 때는 사용 가능한 스캐너 옵션을 신중하게 살펴보고 환경 및 위험 허용 수준에 맞게 설정을 조정해야 합니다. 스캔 시간 및 범위 예약에도 동일하게 적용됩니다. 예를 들어 엔드포인트 세그먼트와 같은 네트워크 영역은 매일 스캔할 수 있습니다. 이는 다운타임 위험이 제한적이고 사용자의 워크스테이션이 잠시 오프라인 상태가 되더라도 그 영향이 크지 않기 때문입니다. 하지만 핵심 운영

데이터베이스와 같은 중요 시스템은 예약된 유지 관리 시간 외에는 스캔하기에 너무 위험할 수 있습니다. 최신 데이터를 확보하는 것과 다운타임 위험을 감수하는 것 사이의 균형을 이해해야 합니다.

네트워크 취약점 스캐너는 본질적으로 네트워크 연결을 통해 발견할 수 있는 취약점만 찾아냅니다. Windows 엔드포인트의 데스크톱 애플리케이션에 로컬에서 악용 가능한 취약점이 있는 경우 네트워크 스캔으로는 이를 찾을 수 없습니다. 예를 들어, 공격자가 조작된 Word 또는 WordPad 문서를 열어야만 악용할 수 있는 Microsoft Equation Editor의 취약점인 CVE-2018-0862는 네트워크 스캐너에서 발견되지 않습니다. 그 이유는 일반적으로 Microsoft Office 애플리케이션은 네트워크 스캔을 통해 탐지되지 않기 때문입니다.

이러한 허점을 메우기 위해 엔드포인트 스캐너(예: Qualys의 "스캔리스 에이전트") 또는 소프트웨어 구성 관리(SCM) 도구나 CMDB를 사용하여 배포된 소프트웨어 버전 목록을 수집하고 취약점 데이터베이스를 참조하여 알려진 취약점을 확인할 수 있습니다. 이러한 한계에도 불구하고 네트워크에서 발견 가능한 취약점만 정확하게 파악하는 것만으로도 훌륭한 출발점이 될 수 있습니다.

취약점 스캐너에 대해서는 3장에서 더 자세히 다루겠습니다.

데이터를 활용하세요

취약점별로 많은 정보가 제공되지만, 여러 데이터 소스를 결합하면 더 많은 정보를 얻을 수 있습니다. 가장 쉽게 접근할 수 있는 것은 익스플로잇 데이터입니다. 공개적으로 사용 가능한 익스플로잇에 대한 정보는 광범위하게 접근 가능하며 검색도 용이합니다. 예를 들어, 익스플로잇 데이터베이스 웹사이트(

<https://www.exploit-db.com/>)는 공개 익스플로잇의 검색 가능한 색인을 제공합니다. 또한, 14장에서 자세히 다룰 Metasploit은 사용 가능한 익스플로잇 아카이브와 이러한 익스플로잇을 대상 시스템에 쉽게 배포할 수 있는 명령줄 도구를 제공합니다. 대부분의 익스플로잇은 특정 취약점, 즉 특정 CVE ID와 연결되어 있습니다. CVE ID를 사용하여 익스플로잇 정보를 이미 보유하고 있는 취약점 정보와 연관시킬 수 있습니다.

악용 가능한 취약점을 해결하는 것은 아직 악용 가능성이 알려지지 않은 취약점을 해결하는 것보다 조직에 더 높은 우선순위를 부여할 가능성이 높습니다. 하지만 모든 공격이 동일한 심각성을 갖는 것은 아닙니다. 예를 들어, 임의 코드 실행을 허용하는 공격은 서비스 거부(DoS) 공격을 유발하거나 임의 데이터 읽기를 허용하는 공격보다 훨씬 더 심각합니다. 공격의 결과를 파악하는 것은 더욱 세분화된 방식으로 공격의 우선순위를 정하는 데 매우 유용합니다.

CVE ID

CVE 데이터베이스는 MITRE Corporation이 주도하여 알려진 모든 정보 보안 취약점을 체계화하고 목록화하려는 시도입니다. 새로 발견된 모든 취약점에는 CVE-*yyyy-xxxx* 형식의 CVE ID가 할당됩니다. 여기서 *yyyy* 는 현재 연도이고 *xxxx*는 네 자리(또는 그 이상) 숫자입니다. 이 데이터베이스는 <https://cve.mitre.org/>에서 온라인으로 이용할 수 있습니다.

CVE 기록에는 취약점에 대한 설명과 함께 공급업체의 공식 취약점 발표, 제3자 알림, 심지어 익스플로잇 발표와 같은 데이터 소스 링크가 포함되어 있습니다. 철저하게 문서화된 취약점의 예로, CVE 웹사이트에서 "CVE-2014-0160"을 검색해 보세요. 이는 거의 모든 웹 서버에 영향을 미친 매우 악명 높은 정보 유출 취약점인 *하트블리드(Heartbleed)*의 식별자입니다. 해당 CVE 페이지에는 메일링 리스트 게시물부터 테스트 도구, 수십 개의 서로 다른 공급업체의 패치 발표에 이르기까지 100개 이상의 참조 자료가 수록되어 있습니다.

고급 데이터 소스

다음 목록에는 몇 가지 전문적이고 고급 데이터 소스가 포함되어 있습니다. 이 책의 범위를 크게 벗어나지만, 유용한 참고 자료가 될 것입니다.

위협 인텔리전스 피드는 현재의 위협 환경에 대한 정보를 제공합니다. 여기에는 위협 행위자 및 그룹, 현재 익스플로잇 키트에 사용되는 익스플로잇, 그리고 아직 공개되지 않은 비공개 익스플로잇이 포함된 취약점 등이 포함됩니다. 이 정보를 활용하여 조직에 가장 큰 위협을 초래하는 취약점을 파악하십시오. 위협 피드는 최신 데이터를 포함하므로, 데이터가 제공되는 즉시 활용하여 새롭게 발견된 위협에 대한 노출 정도를 시의적절하게 평가해야 합니다. iSight Threat Intelligence, iDefense Threat Intelligence, 그리고 FS-ISAC에서 제공하는 것과 같은 업계별 위협 피드 등 다양한 무료 및 유료 위협 피드를 이용할 수 있습니다.

독점 익스플로잇 정보는 비용이 많이 들지만, Exploit Database와 Metasploit에서 공개적으로 제공되는 정보에 독점 익스플로잇 데이터(익스플로잇 키트라고도 함)를 추가하면 취약점 데이터와 비교할 수 있는 익스플로잇의 범위를 넓힐 수 있습니다. 이러한 정보의 출처는 자체적으로 익스플로잇 연구를 의뢰하는 상업적 위협 인텔리전스 기관부터 새로 발견된 취약점 및 익스플로잇 정보를 최고 입찰자에게 판매하는 독립 연구원과 같은 회색 시장 또는 암시장 옵션까지 다양합니다. 출처에 관계없이 독점 익스플로잇 정보는 기존에는 알지 못했던 익스플로잇을 기반으로 자체 취약점 데이터의 우선순위를 더 효과적으로 정하는 데 도움이 됩니다.

네트워크 구성 라우터, 방화벽, 관리형 스위치와 같은 라우팅 장치의 네트워크 구성을 사용하여 네트워크 모델을 구축할 수 있습니다. 이러한 정보(어떤 서브넷이 어떤 서브넷으로 라우팅되는지, 어떤 포트에 어디에서 접근할 수 있는지 등)를 취약점 및 익스플로잇 데이터와 결합하면 네트워크 공격 표면을 심층적으로 파악할 수 있습니다. 예를 들어, 내부 웹 애플리케이션 서버에 대한 Tomcat 익스플로잇이 존재하지만 라우터 구성에서 해당 서버가 제한된 소스 IP 주소 목록에서만 접근 가능하도록 설정되어 있다면, 인터넷 전체에서 접근 가능한 경우보다 덜 우려스러울 수 있습니다. SolarWinds와 같은 중앙 집중식 구성 저장소가 있는 경우 이미 네트워크 구성 정보를 보유하고 있을 가능성이 높습니다. 하지만 이러한 데이터를 기존 취약점 데이터와 통합하는 데에는 상당한 작업이 필요합니다. 일부 상용 취약점 관리 제품에는 네트워크 구성을 수집하는 기능이 내장되어 있습니다.

요약

이 장에서 논의된 각 데이터 소스는 취약점 관리 시스템에 중요한 데이터 세트를 제공합니다. **표 2-1**은 이러한 각 소스에서 얻을 수 있는 데이터를 자세히 보여줍니다.

표 2-1: 취약점 관리용 데이터 소스

데이터 소스	중요 데이터
네트워크 취약점 스캐너	호스트 이름 포트 열기 (TCP 및 UDP) 서비스 및 OS 지문 인식 (위와 동일) 추가 서비스 지문 인식 및 버전 감지 네트워크 취약점 로컬 취약점 (인증된 스캔만 해당)
호스트 기반 취약점 스캐너	지역적 취약점
CMDB/SCM	OS 세부 정보 배포된 소프트웨어 세부 정보 구성 세부 정보 기기 소유자



O'REILLY



데이터 소스	중요 데이터
	기기 및 응용 프로그램의 중요성
데이터베이스를 악용하세요	정보를 악용하세요 취약점과 익스플로잇 간의 매핑
위협 정보	공격자 및 표적 산업 정보 새롭게 발견되었거나, 악화되고 있거나, 광범 위하게 퍼진 악용 사례
익스플로잇 키트	독점적인 익스플로잇 정보
네트워크 구성	네트워크 토폴로지 및 잠재적 공격 경로

다음 장에서는 취약점 스캐닝에 대해 심층적으로 살펴보겠습니다.